For the purposes of these scans, I used the default settings that came with the 15-minute scan. I used these settings for both the authenticated and non-authenticated scans. Below are screenshots that show the setup configuration of both scans.

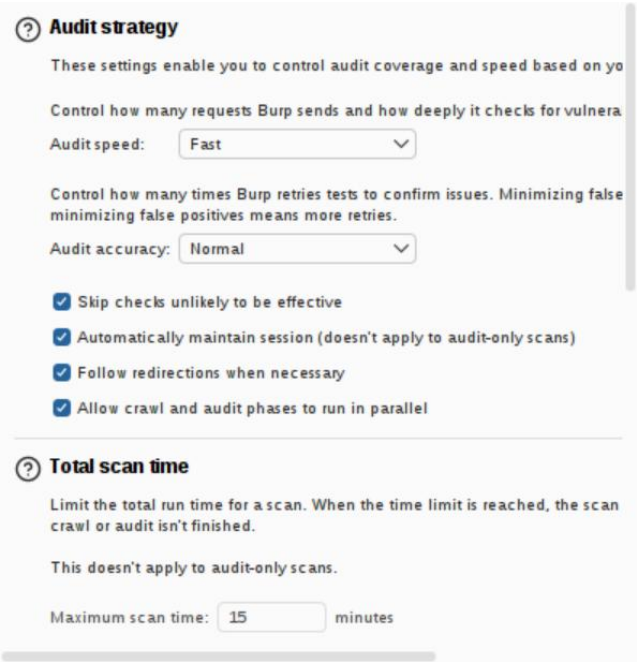


Fig 1. *Audit behavior*

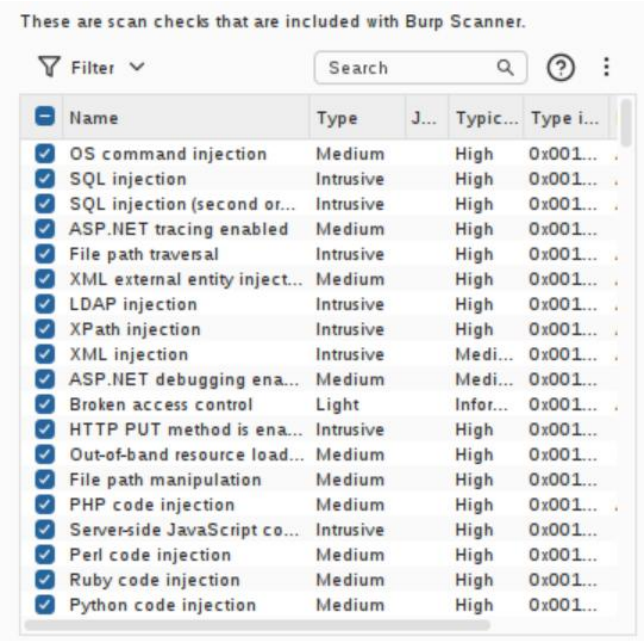


Fig 2. *Scan checks*

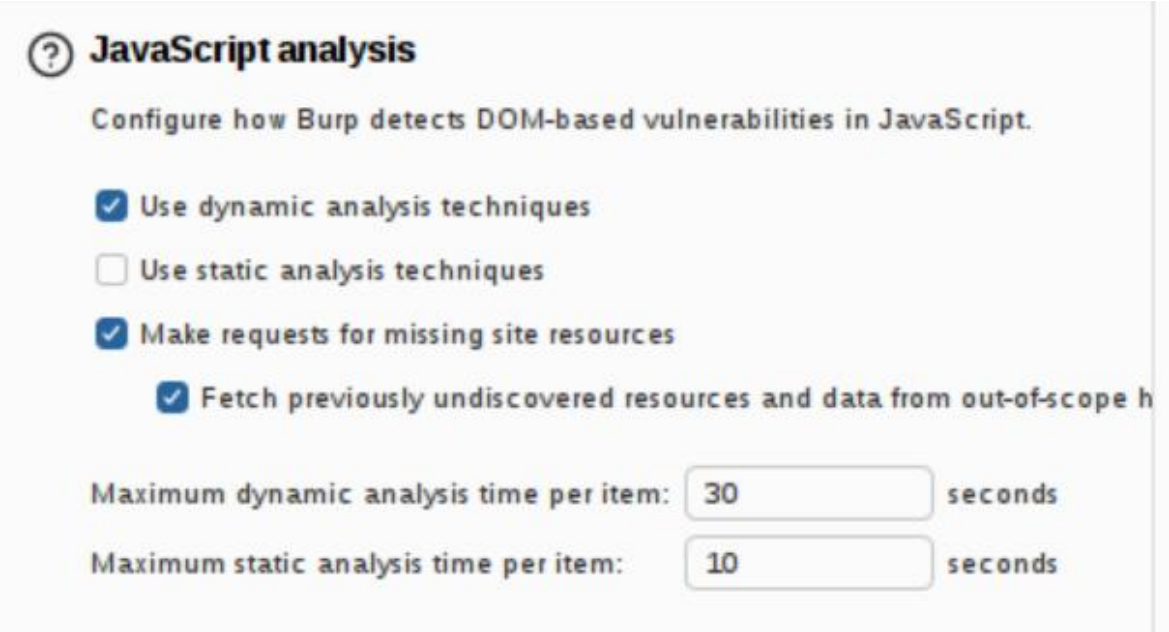


Fig 3. *JavaScript analysis*

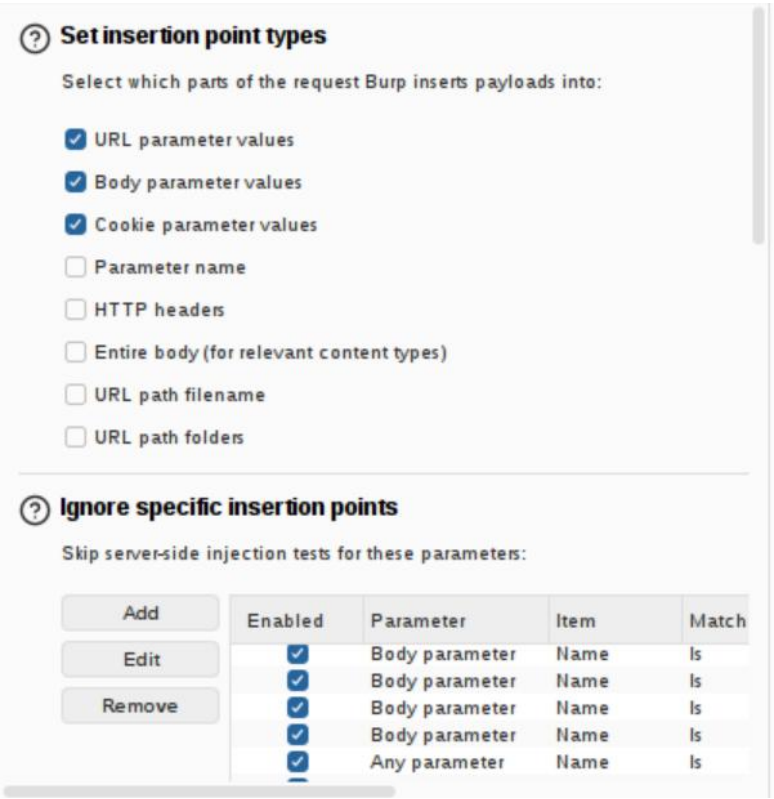


Fig 4. *Insertion points strategy*

Now that we have the scan settings set up the scans can be run. I ran both scans for 15 minutes. The first scan was a non-authenticated scan. This scan didn't have access to the logged-in side of Hackazon. Figure five shows the files that were scanned by this non-authenticated scan. Then figure six shows the results of the scan.

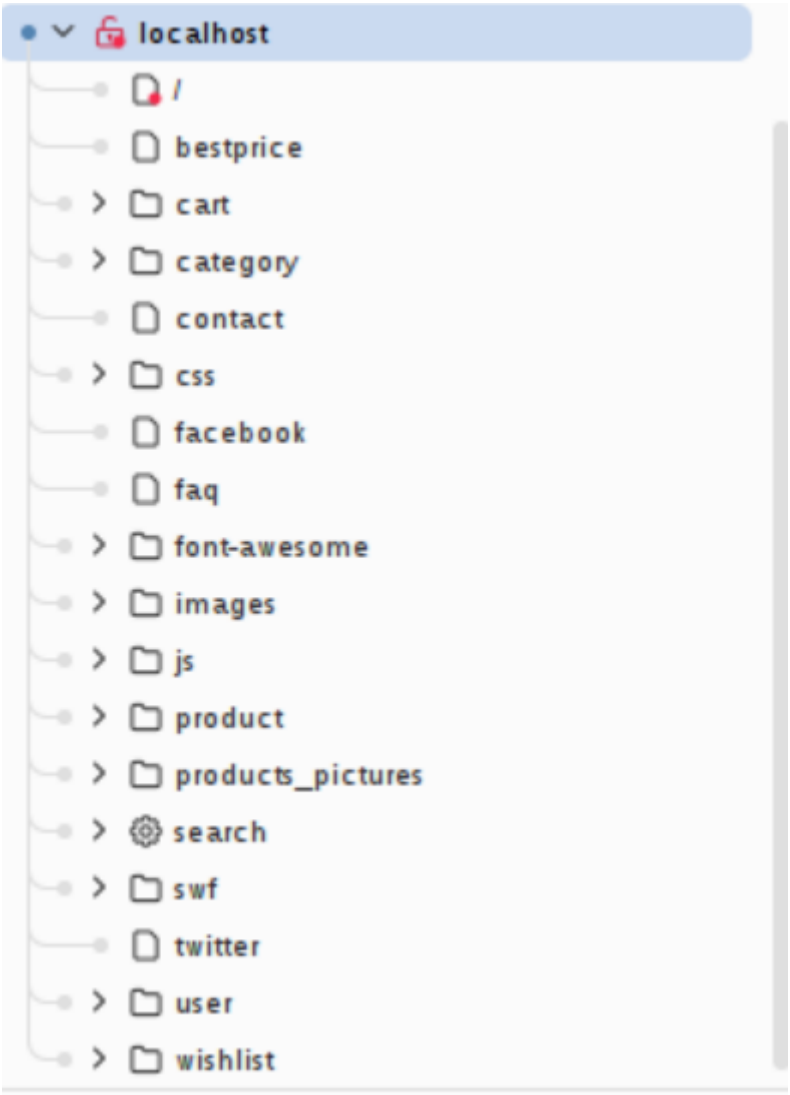


Fig 5. *Non-authenticated scan targets*

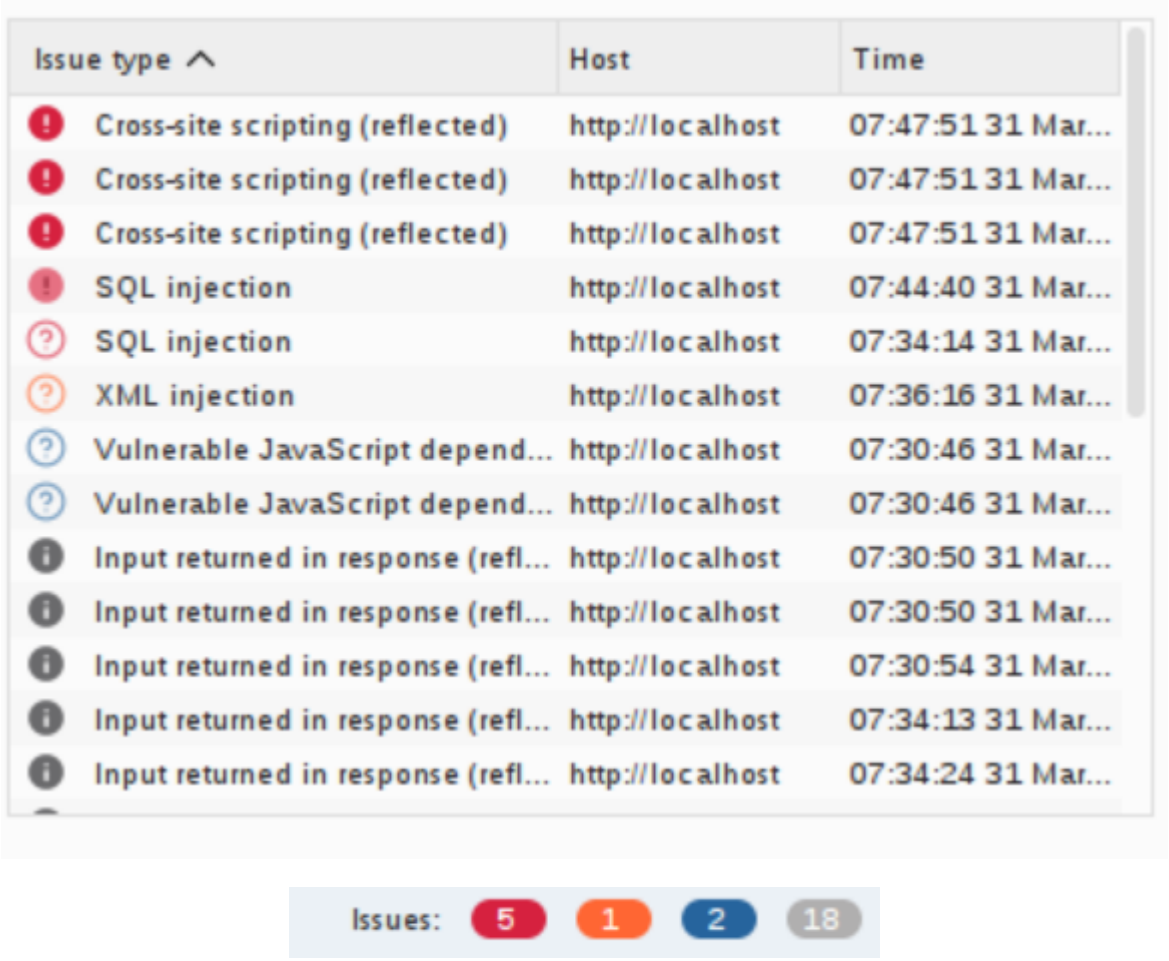


Fig 6. *Results of the non-authenticated scan*

As you can see there are quite a few security issues in Hackazon. There are three XSS vulnerabilities, two SQL injection vulnerabilities and one XML injection vulnerability. There are also two vulnerable JavaScript dependencies and several input return vulnerabilities. The XSS vulnerabilities are major problems. Each XSS vulnerability is tied to a different search function on the Hackazon site. XSS attacks can steal a victims session token, login credentials or log keystrokes. The injection vulnerabilities are another big risk to Hackazon. The injections are possible in the login fields and in the product comments. SQL and XML injections allow an attacker to steal data that normally they shouldn't be able to get. These search bars and comment sections should be sanitized before they are allowed to run the search query. Vulnerable

JavaScript dependencies are a much less risky vulnerability. These JavaScript libraries can be updated to a newer version to increase security. The 18-input returned in response vulnerabilities; I believe are related to the fact that Hackazon is locally hosted and everything is accessed through the files on the local machine.

After the first scan was completed, I logged into Hackazon and did a scan of the authenticated side of the site. Figure 7 shows the account section that was uncovered after logging in.

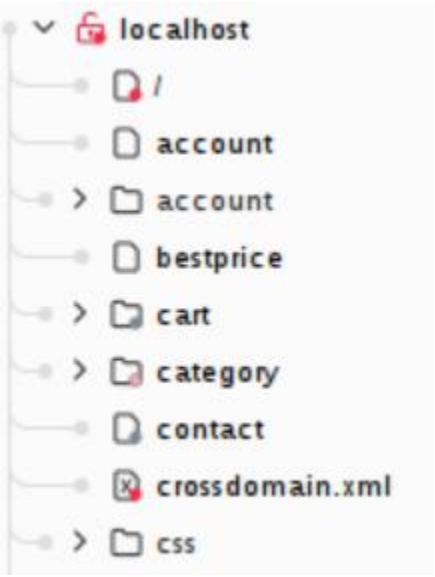


Fig 7. *Authenticated scan targets*

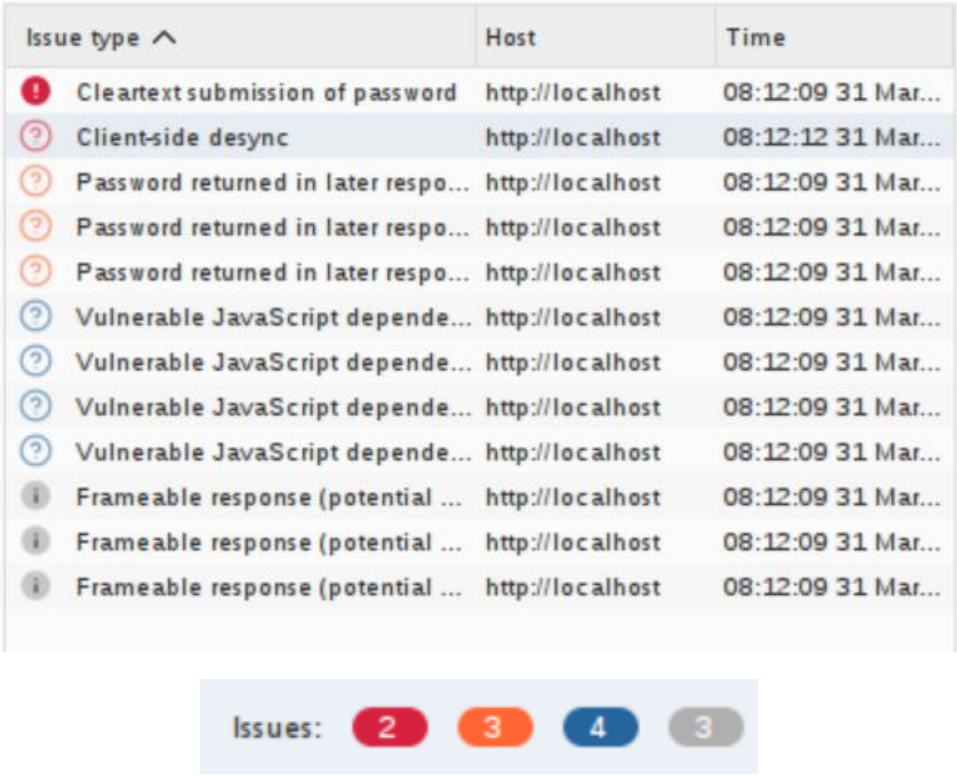


Fig 8. *Results of authenticated scan*

There are less results for the authenticated scan. This is because we only scanned the new sections of the site that appeared after login. The big problems that were found in this section of the site include cleartext password submission, client-side desync, and passwords being returned. The cleartext password is a big vulnerability. The site confirms the password is correct using the internet by using unencrypted HTTP. The site returns the password is correct multiple times through authentication. This could allow an attacker to steal the password on its return.

Sharing this information with the company securely and clearly is important. The first step is to make a fully detailed report of the vulnerabilities found. This report can be used by the client to fix the vulnerabilities. How the data is transferred depends on the severity of the vulnerabilities and how the client wants the data to be moved. The most secure way would be handing the information to the company IT/security team directly. Giving them a USB or drive

that contains the data. However, the data could also be encrypted by PKI or sent through known secure channels.